

Année académique : 2024-2025

Découverte et Analyse de Répertoires Cachés sur Serveurs Web avec DirBuster et Gobuster

Amadou Sy

Etudiant en M1 SSIM

Ecole formation : Groupe IZI

Sous la supervision de :

Monsieur LO

Table des matières

1.	Qu'est-ce que DirBuster ?	2
2.	Caractéristiques :	2
3.	Installation et utilisation de Dirbuster sur kali.....	2
4.	Objectif	3
5.	Exemple de test avec DirBuster	4
5.1.	Configuration de DirBuster	5
5.2.	Résultat de DirBuster	6
5.3.	Observation dans le navigateur	7
6.	Alternative en ligne de commande : Gobuster.....	8
7.	Tableau comparatif : DirBuster vs Gobuster	8
8.	Conclusion	9

1. Qu'est-ce que DirBuster ?

DirBuster est un outil graphique développé par OWASP pour effectuer du brute-forcing de répertoires et de fichiers cachés sur des serveurs web. Il aide à trouver des ressources non listées comme :

- Des dossiers /admin/, /backup/, /test/
- Des fichiers comme login.php, index.old, etc.

2. Caractéristiques :

- **Interface graphique Java (GUI)**
- **Utilisation de threads pour la performance**
- **Très personnalisable : nombre de threads, extensions, profondeur, etc.**
- **Intègre une grande variété de wordlists (incluses par défaut)**

3. Installation et utilisation de Dirbuster sur kali

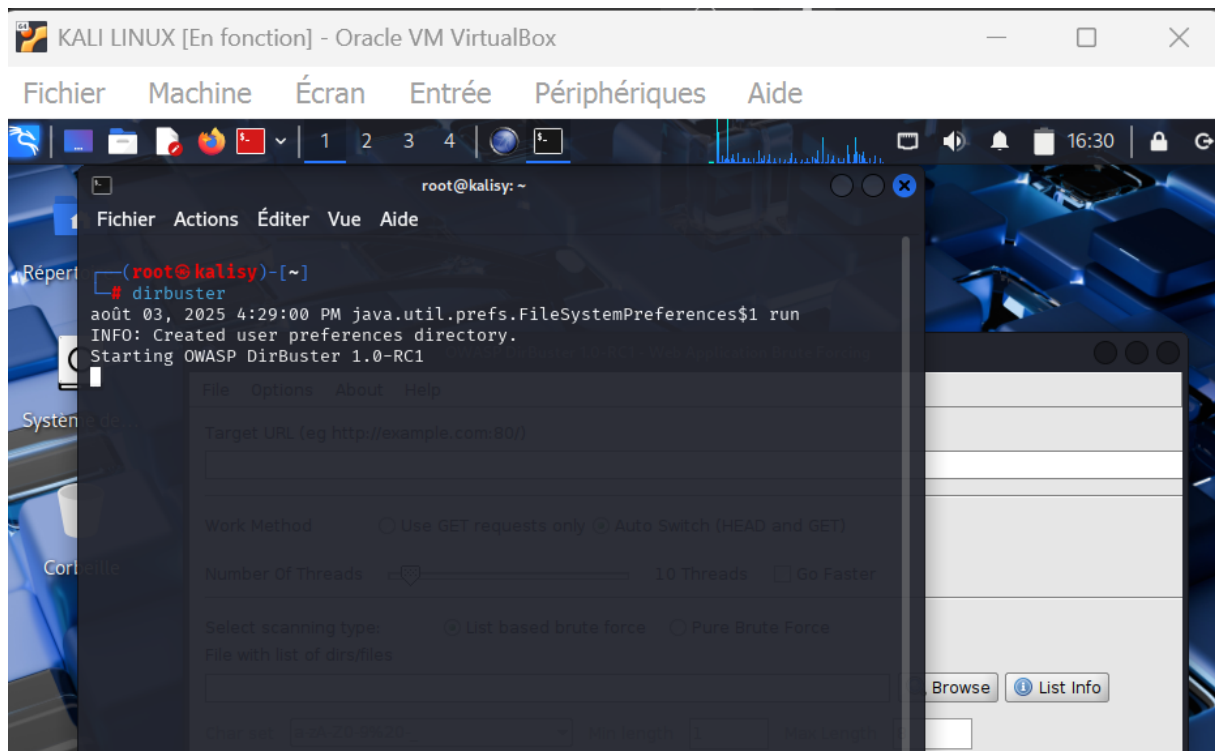
DirBuster est souvent **préinstallé par défaut** sur **Kali Linux**, surtout dans les versions plus anciennes ou les images ISO "full". Toutefois, ce n'est pas systématique :

- Les versions "light" ou personnalisées de Kali peuvent **ne pas l'inclure**.
- Dans les versions plus récentes, **d'autres outils comme gobuster** sont parfois préférés car plus rapides (DirBuster est écrit en Java et peut être lourd à exécuter).

Pour vérifier s'il est installé :

Ouvre un terminal et tape :

dirbuster



Si le programme démarre, c'est bon. Sinon, tu verras une erreur de type "commande introuvable".

Pour l'installer manuellement (si besoin) :

```
sudo apt update
```

```
sudo apt install dirbuster
```

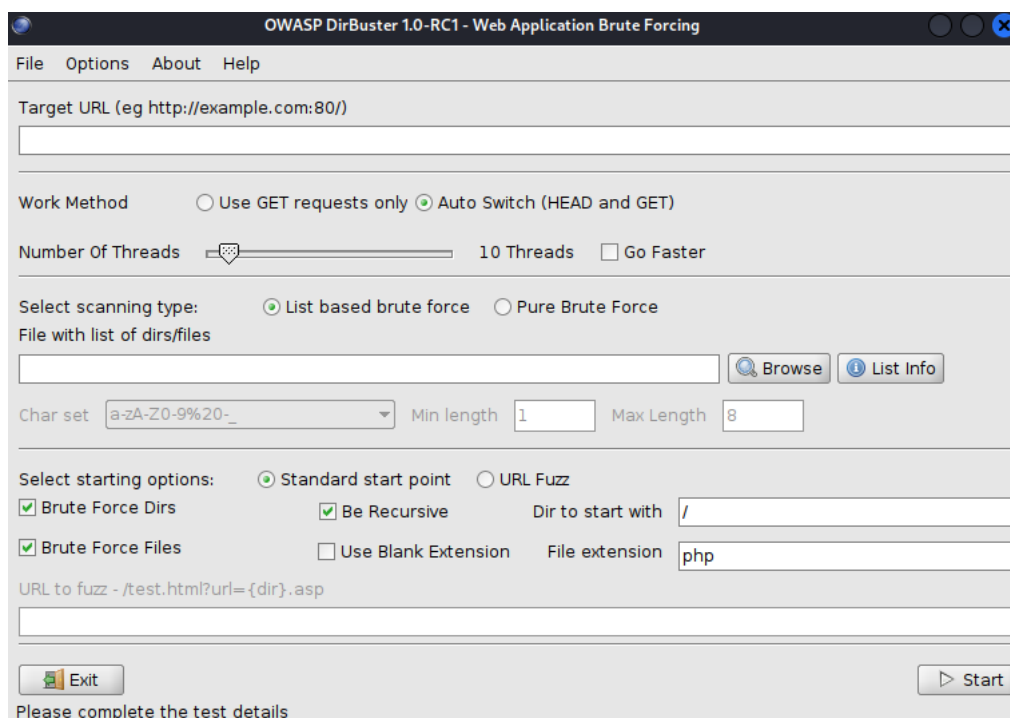
4. Objectif

Trouver des fichiers ou des dossiers cachés sur un serveur web, par force brute.

Important : N'utilisez DirBuster que sur des systèmes que vous possédez ou sur lesquels vous avez une autorisation explicite.

Le lancement de Dirbuster dans le terminal ouvre une interface graphique (GUI)

5. Exemple de test avec DirBuster



On va tester **DirBuster** sur notre machine Ubuntu (192.168.1.38) avec le nom d'utilisateur `mistersy@myserver3`, pour cela il faut :

1. Un **serveur web** (comme Apache ou Nginx) qui tourne sur cette machine.
2. Un site ou quelques répertoires/fichiers à découvrir (même de simples `.html` ou des dossiers dans `/var/www/html`).
3. DirBuster installé (sur Kali ou autre machine attaquante).

```
mistersy@myserver3: ~  
mistersy@myserver3:~$ ifconfig  
enp0s3: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500  
        inet 192.168.1.38 netmask 255.255.255.0 broadcast 192.168.1.255  
  
mistersy@myserver3:~$ cd /var/www/html/  
mistersy@myserver3:/var/www/html$ sudo mkdir secrets admin config  
mistersy@myserver3:/var/www/html$ sudo touch secrets/password.txt  
mistersy@myserver3:/var/www/html$ sudo touch admin/login.html  
mistersy@myserver3:/var/www/html$
```

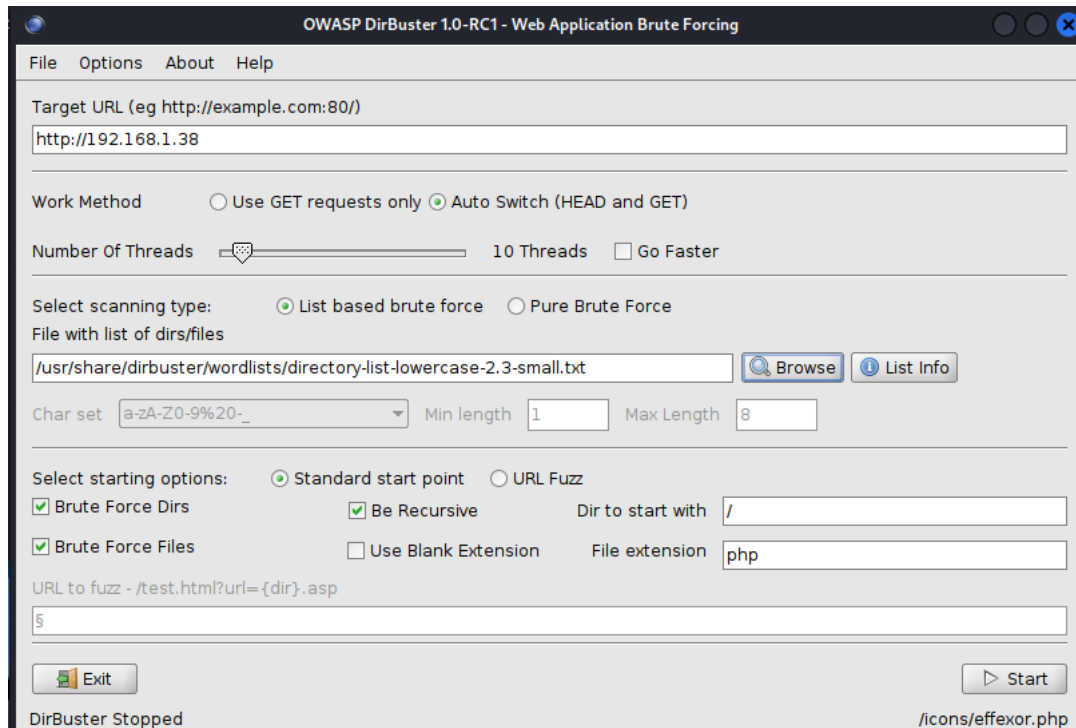
On a maintenant :

- `http://192.168.1.38/secrets/passwords.txt`
- `http://192.168.1.38/admin/login.html`

Mais sans liens visibles sur la page d'accueil — donc idéals à découvrir par force brute.

5.1. Configuration de DirBuster

Lancer DirBuster et Remplir les champs :



Target URL :

- DirBuster est configuré pour effectuer une attaque par force brute sur le serveur web de la machine Ubuntu tournant sur l'adresse IP 192.168.1.38 (port 80 par défaut).

Wordlist utilisée

- Chemin:
/usr/share/dirbuster/wordlists/directory-list-lowercase-2.3-small.txt
 - Liste standard légère, incluse avec DirBuster, contenant plusieurs centaines de chemins couramment utilisés pour détecter rapidement des répertoires web.

Number of Threads :

- **10 Threads :**
 - DirBuster enverra jusqu'à 10 requêtes HTTP simultanément.
 - Bon compromis entre vitesse et stabilité sur un réseau local.

Options :

- Coche "Be Recursive" si tu veux fouiller à l'intérieur de chaque répertoire trouvé.
- Laisse-le reste par défaut.

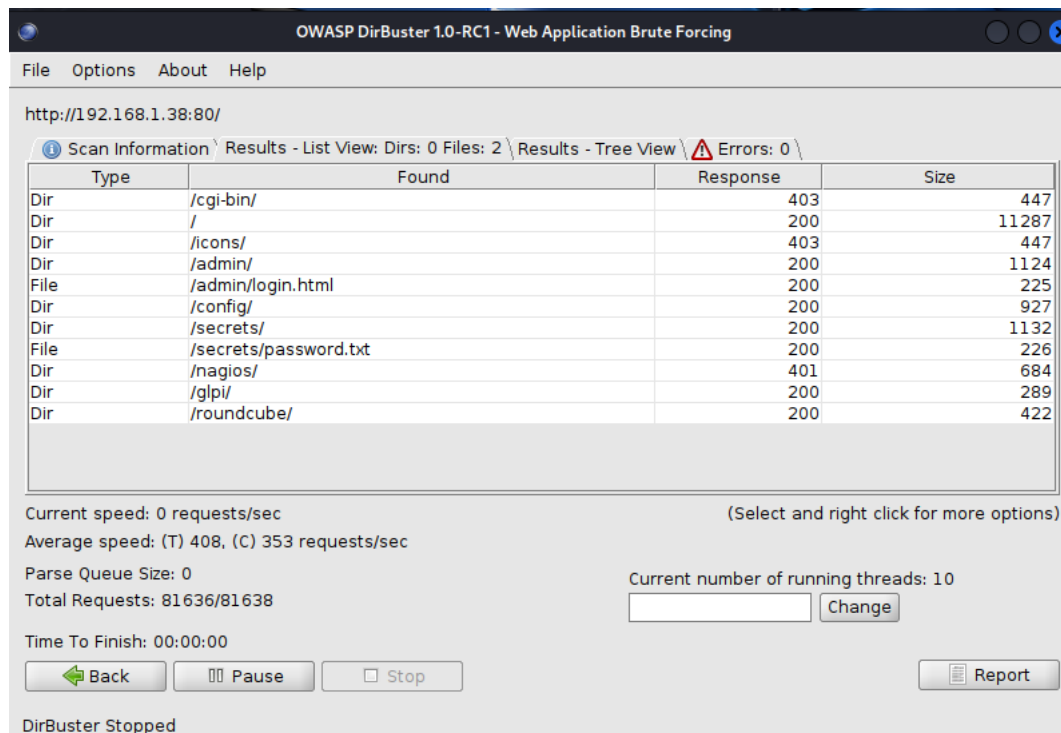
Remarque :

C'est quoi une "wordlist" dans DirBuster ?

Une wordlist, c'est simplement un fichier texte contenant une liste de mots (souvent un mot par ligne).

Dans le cas de DirBuster, ces mots sont utilisés pour tester l'existence de dossiers ou fichiers sur un serveur web.

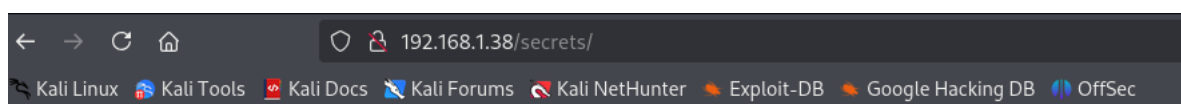
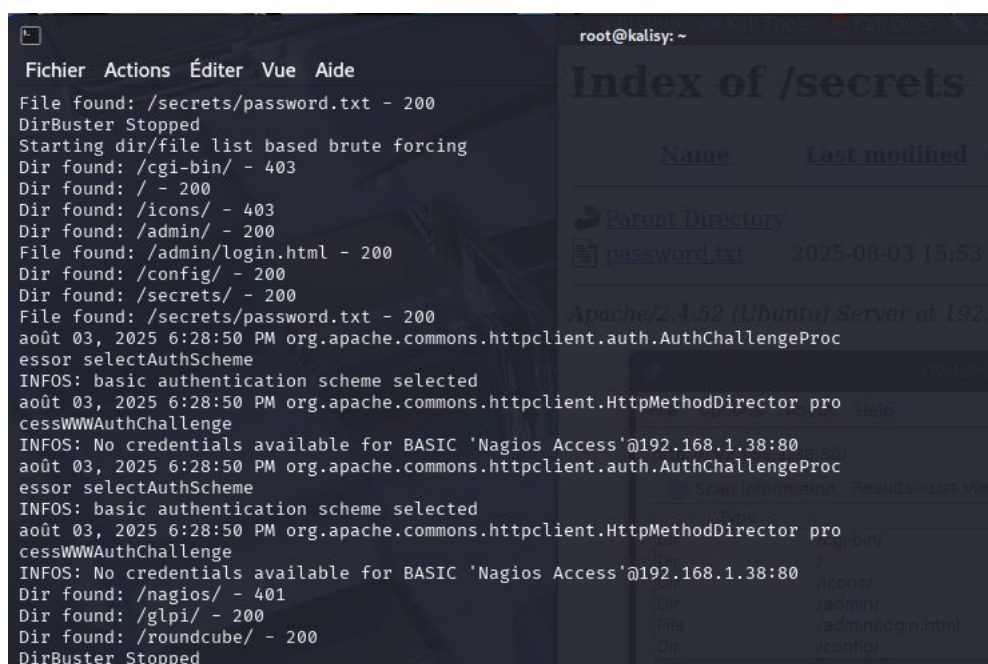
La figure ci-dessous présente le résultat de la phase de découverte de répertoires cachés à l'aide de DirBuster sur la cible :



5.2. Résultat de DirBuster

L'interface de DirBuster indique plusieurs répertoires découverts à l'aide d'une wordlist (directory-list-lowercase-2.3-small.txt).

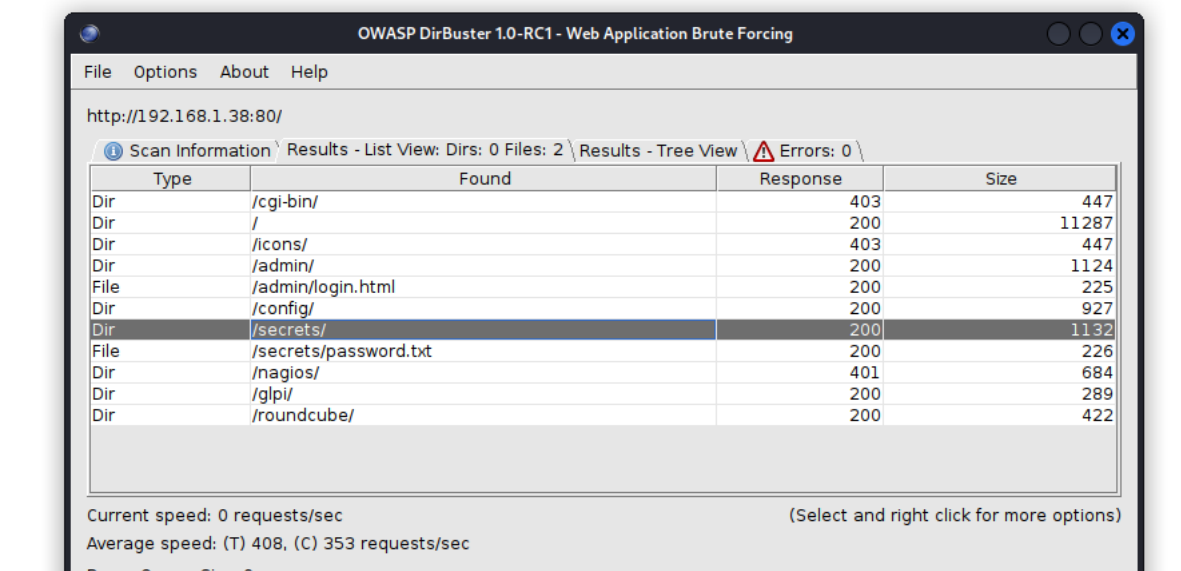
- **Code 200** : la ressource est accessible.
- **Code 403** : (ex : /cgi-bin/, /icons/) : accès interdit, mais le répertoire existe, ce qui peut indiquer un vecteur d'attaque (bypass, LFI...).
- **Répertoires sensibles détectés** : /admin/, /config/, /secrets/ sont typiquement des cibles à haute valeur dans un test d'intrusion.



Index of /secrets

Name	Last modified	Size	Description
Parent Directory	-	-	-
password.txt	2025-08-03 15:53	0	

Apache/2.4.52 (Ubuntu) Server at 192.168.1.38 Port 80



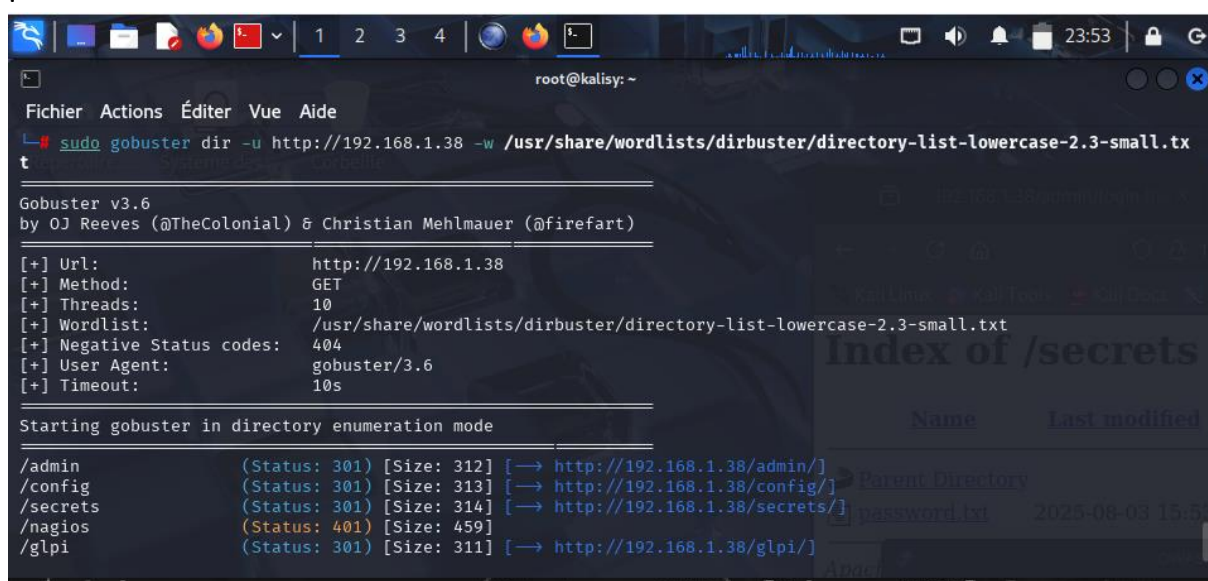
5.3. Observation dans le navigateur

Le navigateur affiche le contenu du répertoire /secrets/, découvert par DirBuster. Ce dossier est listé publiquement (indexation activée) et contient un fichier nommé password.txt. Ce fichier constitue une information sensible qui pourrait être exploitée dans le cadre d'un test de sécurité.

6. Alternative en ligne de commande : Gobuster

Pour ceux qui recherchent une alternative plus rapide à DirBuster, **Gobuster** constitue un excellent choix. Il s'agit d'un outil de **brute forcing en ligne de commande**, développé en langage **Go**. Gobuster est principalement utilisé pour découvrir :

- Des répertoires et fichiers cachés sur un site web,
- Des sous-domaines (DNS),
- Des URIs d'API REST,
- Des buckets S3,
- Des hôtes virtuels (VHosts).



```
root@kali: ~  
Fichier Actions Éditer Vue Aide  
# sudo gobuster dir -u http://192.168.1.38 -w /usr/share/wordlists/dirbuster/directory-list-lowercase-2.3-small.txt  
Gobuster v3.6  
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)  
[+] Url: http://192.168.1.38  
[+] Method: GET  
[+] Threads: 10  
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-lowercase-2.3-small.txt  
[+] Negative Status codes: 404  
[+] User Agent: gobuster/3.6  
[+] Timeout: 10s  
Starting gobuster in directory enumeration mode  
/admin (Status: 301) [Size: 312] [→ http://192.168.1.38/admin/]  
/config (Status: 301) [Size: 313] [→ http://192.168.1.38/config/]  
/secrets (Status: 301) [Size: 314] [→ http://192.168.1.38/secrets/]  
/nagios (Status: 401) [Size: 459]  
/glpi (Status: 301) [Size: 311] [→ http://192.168.1.38/glpi/]
```

Gobuster est plus **récent** et **légèrement plus performant** que DirBuster, notamment grâce à son architecture légère, sans interface graphique. Il est particulièrement adapté aux environnements automatisés, aux audits rapides et aux intégrations dans des pipelines d'analyse.

La version stable actuelle de Gobuster est **v3.6** (publiée en **2024**).

7. Tableau comparatif : DirBuster vs Gobuster

Critère	DirBuster (GUI)	Gobuster (CLI)
Date de création	~2007	2016
Interface	Graphique (Java)	Ligne de commande
Vitesse	Moyenne (moins rapide)	Très rapide (Go)

Critère	DirBuster (GUI)	Gobuster (CLI)
Automatisation	Difficile	Facile à script/programmer
Ressources	Plus lourd	Léger
Cas d'usage	Débutants, tests ponctuels	Pentests pro, automatisés

8. Conclusion

L'utilisation de **DirBuster** dans un contexte de test de pénétration permet d'effectuer **une découverte efficace** et automatisée des répertoires et fichiers cachés sur un serveur web. Grâce à une exploration basée sur des wordlists prédéfinies, l'outil met en évidence des ressources non référencées mais accessibles, comme des interfaces d'administration, des fichiers de configuration ou encore des documents sensibles.

Dans notre cas, l'analyse de la cible `http://192.168.1.38` a permis d'identifier plusieurs répertoires critiques, dont `/admin/`, `/config/`, et `/secrets/`, ainsi que le fichier `password.txt`, pouvant contenir des informations confidentielles. Ces éléments auraient pu échapper à une simple navigation manuelle.

DirBuster s'avère donc être **un outil essentiel pour la phase de reconnaissance d'un test de sécurité**, notamment lorsqu'il s'agit de cartographier l'arborescence d'un site ou de détecter des points d'entrée oubliés par les développeurs. Il est cependant recommandé de compléter cette analyse avec des outils en ligne de commande comme Gobuster pour gagner en rapidité et automatisation.

Enfin, ce type de détection doit toujours être réalisé **dans un cadre légal**, avec l'autorisation explicite du propriétaire du système cible.

Sources d'information utilisées

Gobuster

➤ Dépôt GitHub officiel :

 <https://github.com/OJ/gobuster>

→ Source principale pour :

- Date de création : Le premier commit date de mai 2016.
- Dernière version stable : v3.6, publiée en 2024 (voir *Releases*).

DirBuster

➤ Code source historique (Google Code archive ou GitHub forks)

→ DirBuster date d'environ **2007–2008**, et n'est plus activement maintenu depuis plusieurs années.